

Producción de Software

Pablo Valenzuela

11 Mayo 2026

Research Directions in Software Supply Chain Security

1. El software moderno como cadena de suministro
2. Tres vectores principales de ataque
3. Vector 1: dependencias y components
4. Vector 2: infraestructura de build y deployment
5. Vector 3: humanos, cultura y confianza
6. Temas transversales: SBOM, trazabilidad, LLMs y estándares
7. De la confianza implícita a la confianza verificable

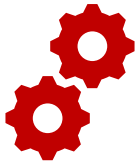
1. El software moderno como cadena de suministro



1. El software moderno como cadena de suministro

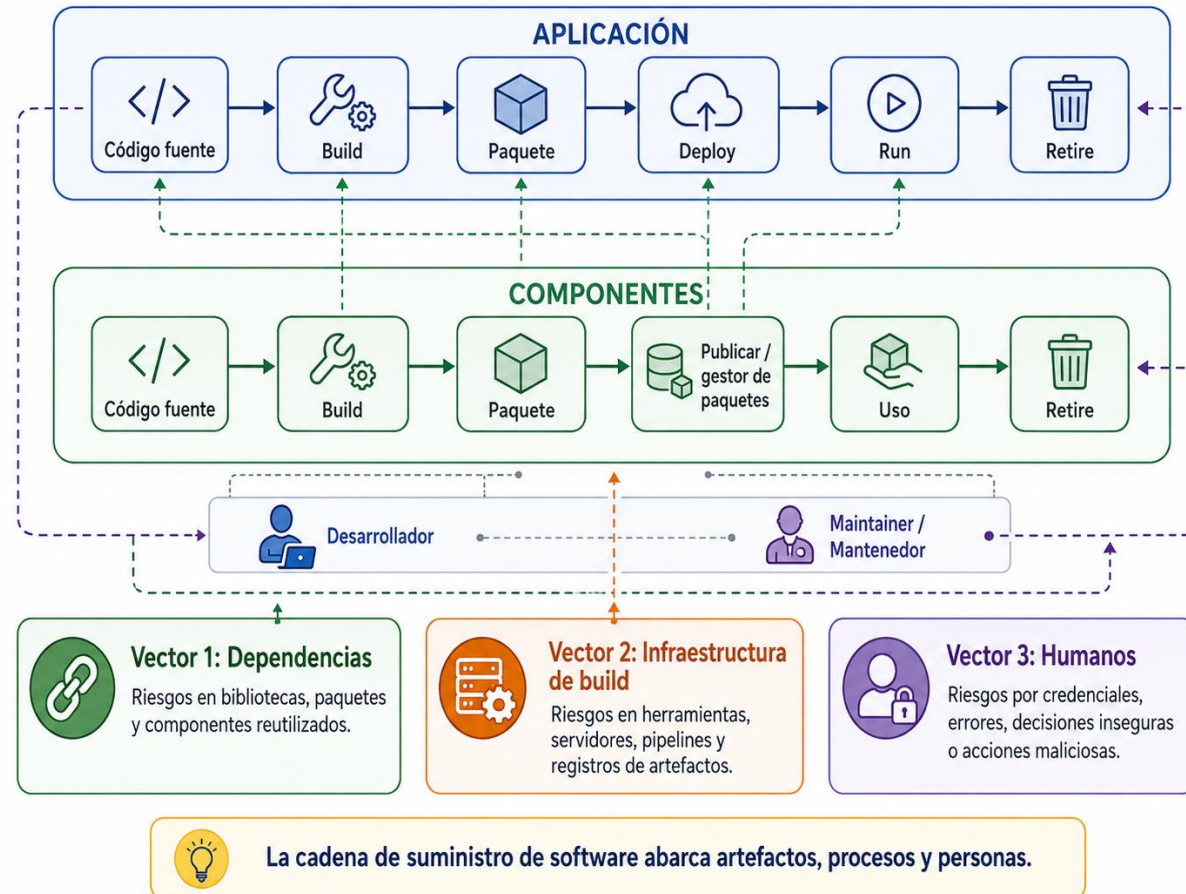


Crear herramientas que ayuden a las organizaciones a visualizar su cadena de suministro completa



Una oportunidad clara es construir un “mapa vivo” del software: qué componentes usa, quién los mantiene, cómo se construyen, qué servicios externos intervienen y qué partes de la cadena no son observables.

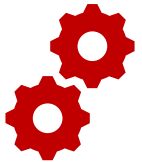
2. Tres vectores principales de ataque



2. Tres vectores principales de ataque



Desarrollar plataformas de evaluación de riesgo que integren los tres vectores en lugar de analizarlos por separado



Se podría ofrecer un puntaje de exposición combinando vulnerabilidades en dependencias, riesgos del pipeline y señales organizacionales como permisos, revisiones, mantenedores y credenciales.

3. Vector 1: dependencias y componentes

Vector 1: Dependencias y componentes

Las dependencias aportan funcionalidad, pero también introducen riesgo acumulado, transitivo y difícil de priorizar.

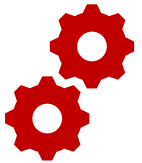


Las decisiones sobre dependencias requieren contexto técnico, mantenimiento y exposición real.

3. Vector 1: dependencias y componentes

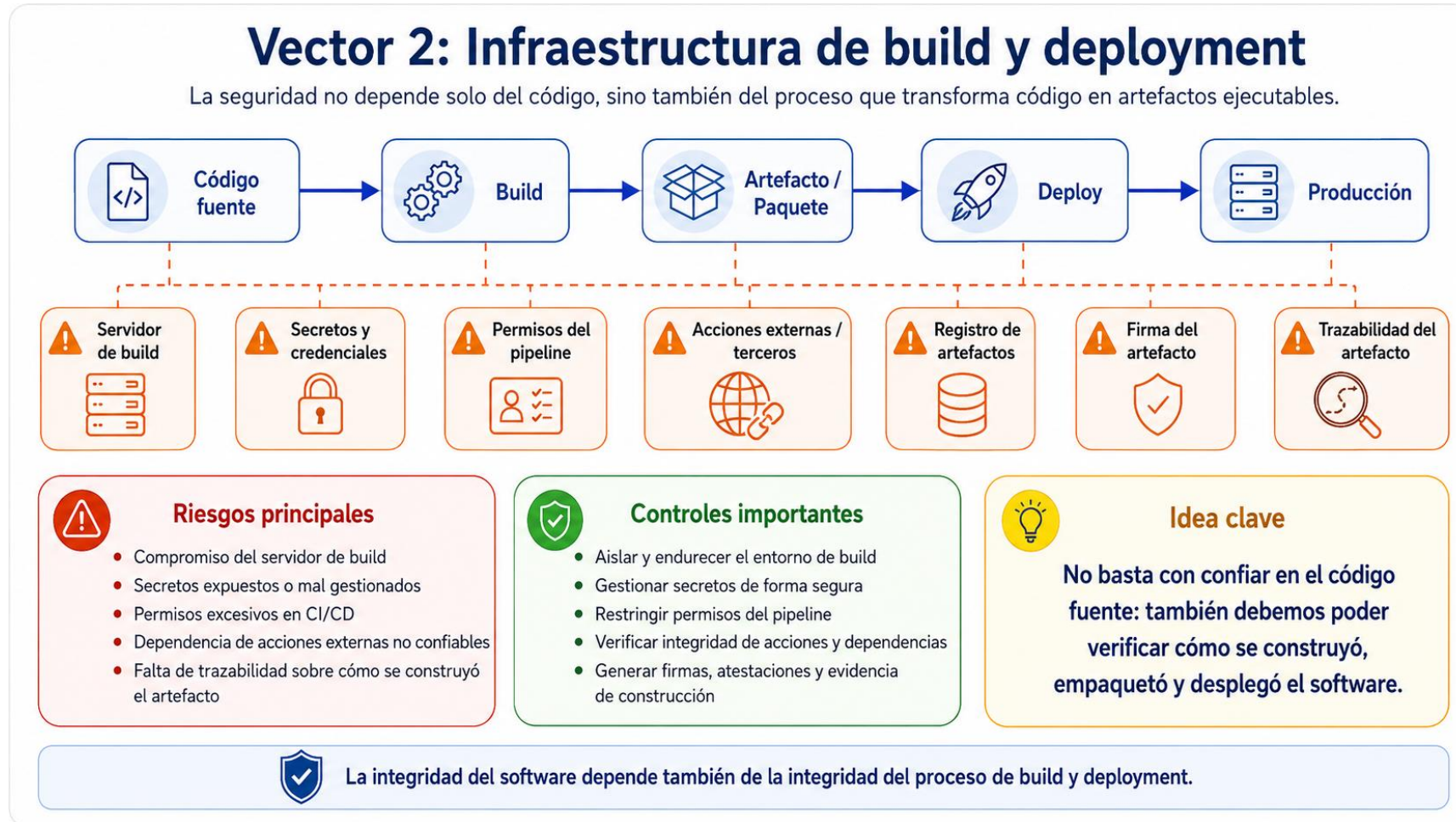


Investigar mejores métricas para elegir dependencias seguras



Una oportunidad de producto sería un asistente de selección de componentes que no solo muestre CVEs, sino señales de mantenimiento, actividad del proyecto, historial de releases, popularidad, velocidad de respuesta a vulnerabilidades, riesgo de abandono y compatibilidad con el proyecto.

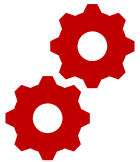
4. Vector 2: infraestructura de build y deployment



4. Vector 2: infraestructura de build y deployment

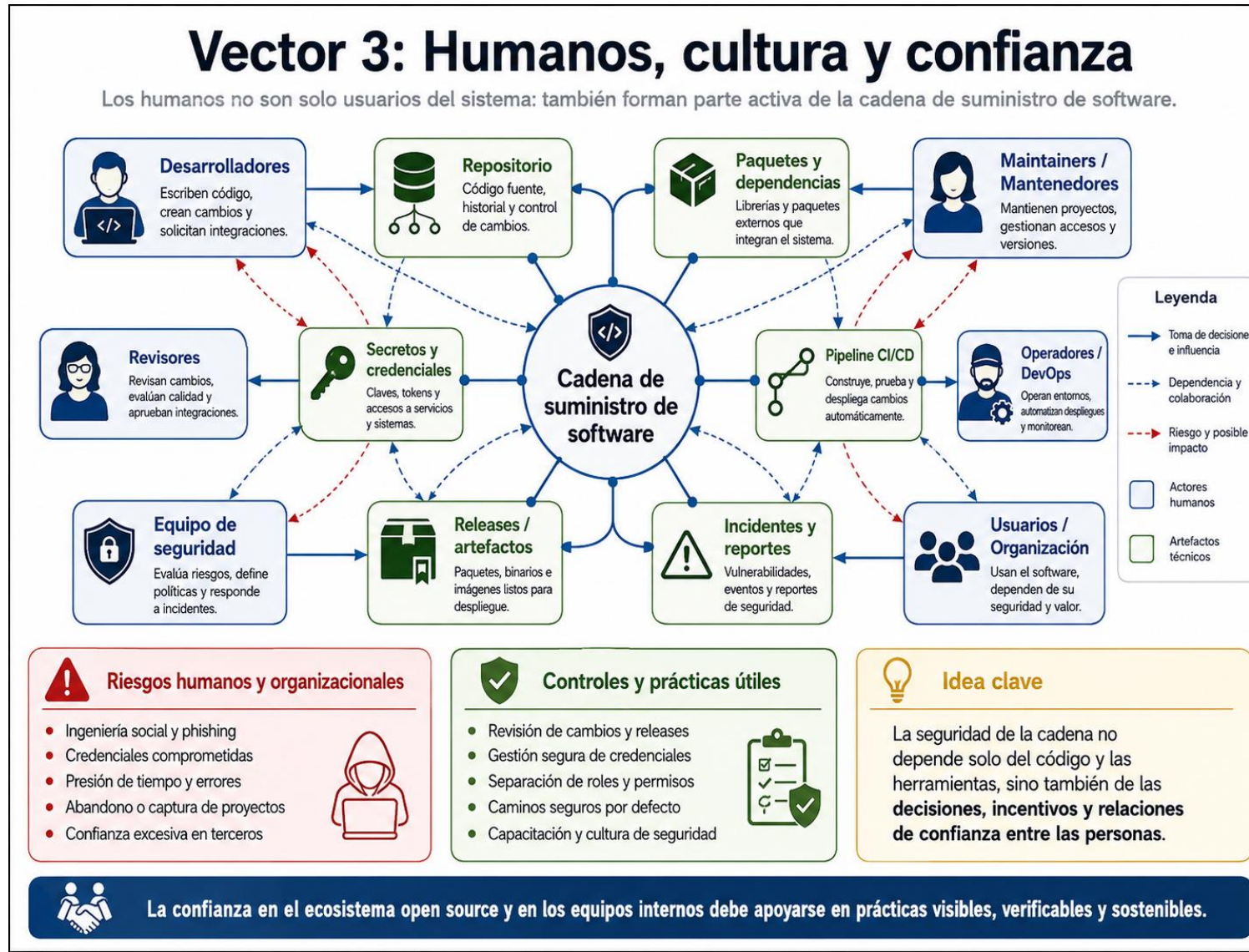


Crear herramientas de análisis de seguridad para pipelines CI/CD.



Se podría ofrecer “CI/CD security posture management” enfocado en integridad del build y trazabilidad de artefactos.

5. Vector 3: humanos, cultura y confianza



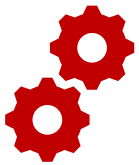
6. Temas transversales: SBOM, trazabilidad, LLMs y estándares



6. Temas transversales: SBOM, trazabilidad, LLMs y estándares



Construir herramientas que conviertan SBOMs en decisiones accionables.



Una oportunidad es un sistema que consuma SBOMs, detecte exposición, priorice vulnerabilidades, sugiera remediaciones, evalúe licencias y genere evidencia para auditorías.

7. De la confianza implícita a la confianza verificable

De la confianza implícita a la confianza verificable

Decisiones seguras basadas en evidencia y trazabilidad.



Objetivo

Construir y entregar software seguro y resiliente, con visibilidad, trazabilidad y mejora continua.



Referencias



Williams, L., Benedetti, G., Hamer, S., Paramitha, R., Rahman, I., Tamanna, M., Tystahl, G., Zahan, N., Morrison, P., Acar, Y., Cukier, M., Kästner, C., Kapravelos, A., Wermke, D., & Enck, W. (2025). *Research directions in software supply chain security*. **ACM Transactions on Software Engineering and Methodology**, 34(5), Article 146. <https://doi.org/10.1145/3714464>